Sapienza University of Rome

Cybersecurity
PhD in Cybersecurity

Ethical hacking

Thesis Advisor
Prof. XXX XXX

Candidate
Name
matricola

Academic Year MMXIX-MMXXII (XXXV cycle)

Contents

1 Casing the Establishment **1**
1.1 Hackers tools . . . 1
1.1.1 *Tor* . . . 1
1.1.2 Vidalia . . . 2
1.1.3 Privoxy . . . 2
1.2 Footprinting . . . 2
1.2.1 publicly available information . . . 2
1.2.2 Public Database Security Countermeasures . . . 3

2 Scanning **4**
2.1 Objectives . . . 4
2.2 Determining if the system is alive . . . 4
2.2.1 same subnet . . . 4
2.2.2 remote host/router . . . 4
2.2.3 TCP/UDP host discovery . . . 4
2.2.4 Ping sweep countermeasures . . . 4
2.3 determining which service are running or listening . . . 5
2.3.1 Port scanning . . . 5
2.4 Detecting the Operating System . . . 5
2.4.1 Countermeasures . . . 5
2.5 Processing and storing data . . . 6

3 Enumeration **7**
3.1 What is enumeration? . . . 7
3.1.1 vulnerability scanners . . . 7
3.1.2 basic banner grabbing . . . 7
3.1.3 DNS enumeration tools and countermeasures . . . 8

4 Hacking Windows and Rainbow Tables **9**
4.1 . . . 9

5 Cybercrime and Advanced Persistent Threats **10**
5.1 . . . 10

6 Remote Connectivity and VoIP Hacking **11**
6.1 . . . 11

7 Wireless Hacking **12**
7.1 . . . 12

8 Hacking Hardware **13**
8.1 . . . 13

9 Web Application Hacking **14**
9.1 14

10 Mobile Hacking **15**
10.1 15

Bibliography **16**

Chapter 1

Casing the Establishment

1.1 Hackers tools

It's All About Anonymity, Stupid (IAAAS)

Hackers use a wide variety of tools:

- *The Onion Router (Tor)*, wich uses Layered cryptography with SOCKS proxy and Anonymous outgoing TCP connections
- Tor GUI client (Vidalia) and Privoxy (web filtering proxy)
- Google on browser for juicy targets
- tor-resolve instead of host for IP addresses
- proxychains to force connections through Tor and Nmap to scan service on targets
- socat to relay persistently, netcat to send requests to servers

1.1.1 *Tor*

How it works:

1. Alice *Tor* client obtain a list of *Tor* nodes from a directory server
2. Alice *Tor* client picks a random path trough the nodes to the destination, using encrypted links

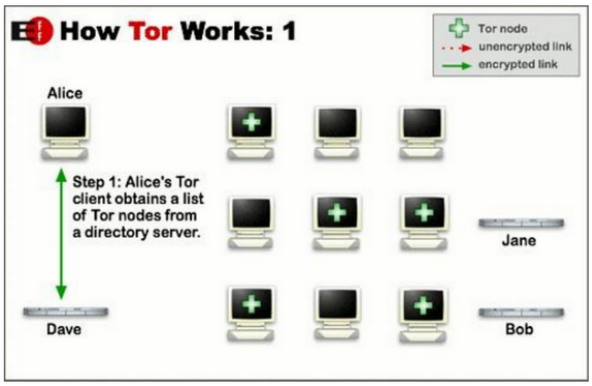

Figure 1.1: first step

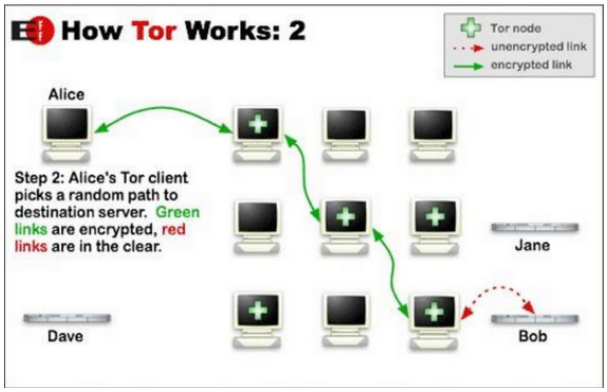

Figure 1.2: second step

1.1.2 Vidalia

Vidalia is a discontinued cross-platform GUI for controlling Tor. It allows the user to start, stop or view the status of Tor

1.1.3 Privoxy

Privoxy is a free web proxy for enhancing privacy, manipulating cookies and modifying web page data and HTTP headers before the page is rendered by the browser. E.g. filtering web pages and removing advertisements. Privoxy can be customized by users.

1.2 Footprinting

What is footprinting? its the profiling of the target organization. It has to be done to give a picture of what the hacker can see. It has to be done regularly to minimize info leaks and implement monitoring

The profiling comprehend:

- Internet: domain names, network blocks and subnets, IP, TCP/UDP services, access controll, IDS, DNS hostnames, CPU arch, system enumeration
- intranet: network protocols, intranet domain names, network blocks, IP, TCP/UDP services
- Remote access: phone numbers, remote system type, VPN, authentication mechanism
- Extranet: domain names, connection source and destination, access control, type of connection

Profiling steps:

1. Determine the scope of the activities
2. get proper authorization trough politics and founding
3. use publicly available information
4. WHOIS and DNS enumeration: Domain names, IP addresses, port numbers
5. DNS interrogation: obtain info about the organization by querying DNS server, DNS zone transfer by untrusted users. Use nslookup to map all resource records. Search with grep,sed,awk,perl
6. network reconnaissance: topology and access path diagram using traceroute, tracert, visualroute, McAfee's NeoTrace, Foundstone's Trout, Owasp AMASS

1.2.1 publicly available information

There are a lot of information on the internet that we can use:

- HTML source code: using website mirroring tool for offline viewing, and reading things inside comment tags

- Enumerate hidden files and directories
- remote access to internal resources via browser: proxy to internal service
- looking for other website other than the main (web, test, VPN sites)
- related organization, to do a social engeneering attack or, in outsourced web developement, partners might not be as secure
- location details such as images or geolocalization: needed for surveillance, social engeneering, unauthorized access
- names: usernames, e-mail addresses
- phone number, phisical addresses
- employees personal details: home phone number, address, social security number, credit history, family ancestry, photos
- busness directory services
- job posting and resumes, ex employees
- employee home computers, for remote access to target, keystroke logger to see the passwords
- company history: mergers, acquisitions, scandals, layoff, hiring, reorganization, outsourcing, temorary contractors, business info, stock market sites
- privacy and security policies
- archived information

1.2.2 Public Database Security Countermeasures

A lot of countermeasures can be taken to minimize the leakage of data:

- keeping administrative contacts up to date
- anonymize administrative contacts
- authenticate updates rigidly
- restrict zone transfer to only authorized servers
- Configure a firewall to deny unauthorized connection to TCP port 53
- configure not to provide internal DNS info
- discourage the use of HINFO records
- use intrusion detection: snort,bro
- Configure border routers to limit ICMP and UDP traffic to specific systems

Chapter 2

Scanning

2.1 Objectives

1. determining if the system is alive
2. determining which service are running or listening
3. detecting operating system
4. Processing and storing data

2.2 Determining if the system is alive

2.2.1 same subnet

Using ping sweeps: we can use ARP-SCAN, Nmap, Cain. NMAP sends an ICMP ECHO request and ARP ping and TCP ping. If the target network is monitored by in IDS you could trigger an alert for the extra traffic generated

2.2.2 remote host/router

For a remote host we can use ICMP ECHO REQUEST, ICMP ECHO REPLY,ICMP TIMESTAMP,ICMP ADDRESS MASK Others useful tools are: ping, nmap, hping3, nping, Superscan

2.2.3 TCP/UDP host discovery

When internal or external ICMP is not permitted. For servers we use TCP/UDP service ports, for desktop we use local firewall trough remote desktop

2.2.4 Ping sweep countermeasures

Two type of countermeasures:

- Detection: using IDS, commercial firewalls and host based tools like Scanlogd, courtney, ippl, protolog

- Prevention: using ACL in firewall to limit ICMP traffic in the network or system, allowing only ECHO REPLY, HOST UNREACHABLE, PROTOCOL UNREACHABLE, PORT UNREACHABLE, TIMESTAMP EXCEEDED only in specific host in DMZ. Allow only ISP's specific IP addresses

2.3 determining which service are running or listening

2.3.1 Port scanning

Port scanning has the objective to:

- identify TCP/UDP services running on the target host
- identify the type of OS of the target
- identify application or version of the service

There are different types of port scanning:

- TCP connect scan(3 way handshake)
- TCP SYN scan (half open scan)
- TCP FIN scan
- TCP NULL scan
- TCP Xmas scan
- TCP ACK scan
- TCP Window scan
- TCP windows scan
- UDP scan

2.4 Detecting the Operating System

OS detection is useful info for vulnerability mapping. There are different techniques for OS detection: banner grabbing: using FTP, SMTP, HTTP, POP. Stack fingerprinting: using TCP/IP stack implementation, making guesses from available ports (windows and unix have OS specific ports)

2.4.1 Countermeasures

Two type of countermeasures:

- Detection: using Snort, Scanlog, option set
- Prevention: changing unique stack charateristic(not recommended), using a secure proxy or firewall, Active Defense.

2.5 Processing and storing data

The efficency to manage scan data is the speeed of the attack, and the number of system compromised. Metasploit offers a vast platform of tools payloads and exploits

Chapter 3

Enumeration

3.1 What is enumeration?

The difference between scannin and enumeration is the level of intrusiveness, and enumeration active cnnection to system and directed query, while scannin is passive. Enumerated info comprehend: User account names, misconfigured shared files, older software version with known vulnerabilities, and default accounts and passwords.

3.1.1 vulnerability scanners

There are a lot of tools for vulnerability scanning:

- Using database of known vulnerabilities
- free scanners like: Nessus, OpenVAS
- Nessus provides a lot of tools, like: exhaustive scanning, custom plug ins, open source. Nessus countermeasures are: using IDS/IPS and audit yourself regularly.

3.1.2 basic banner grabbing

Banner grabbing is the process of analyze the banner of a service to obtain info about the software and version. The banner are the response messages of an open port. It can be done manually using telnet, or automatically using netcat or nc. The countermesure are: shutting down unecessary services, using an access control list, audit yourself regularly.

The most common services to grab are:

- FTP, TCP 21: FTP password are sent in clear. The countermeasures are: using HTTP instead of FTP and disallow unresricted uploading
- Telnet, TCP 23: it has banners and alows bruteforce username enumeration. It sends password and data in cleartext. The countermeasures are: stop using telnet, or use a VPN, modify banner info, reconnect between failed login attempts.
- SMTP, TCP 25: SMTP can be enumerated with telnet using the commands VRFY (to confirm names of valid user) and EXPN (to reveal the actual delivery addresses of alias and

mailing lists). The countermeasure is to disable EXPN and VRFY commands or restrict them to authenticated users

- HTTP, TCP 80
- DNS, TCP/UDP 53: Zone transfer dump the entire contents of a domain's zone files. Its restricted to authorized machine on most DNS servers
- TFTP, UDP 69
- Finger, TCP 79

3.1.3 DNS enumeration tools and countermeasures

- dnsenum: google scraping for additional subdomain, brute forcing subdomains, list domains network ranges, performs WHOIS on the ranges identified, Information correlation
- Fierce.pl

The countemeasures are:

- Using separate internal and externa DNS servers
- block or restrict DNS zone transfer
- restrict DNS queries to limit caache snooping

Chapter 4

Hacking Windows and Rainbow Tables

4.1

Chapter 5

Cybercrime and Advanced Persistent Threats

5.1

Chapter 6

Remote Connectivity and VoIP Hacking

6.1

Chapter 7

Wireless Hacking

7.1

Chapter 8

Hacking Hardware

8.1

Chapter 9

Web Application Hacking

9.1

Chapter 10

Mobile Hacking

10.1

Bibliography